

CASE-004

DNS Tunnelling & HTTPS C2 Detection

Technical Security Report | Home Lab Detection Engineering

Analyst	Nwodu Robert	Case ID	CASE-004
Date	July 18, 2026	Classification	Confidential
Environment	Home Lab (VirtualBox)	Status	Completed
Tools Used	Zeek · Splunk · dnscat2 · Metasploit	Severity	HIGH

1. EXECUTIVE SUMMARY

This report documents the design, simulation, and detection of two advanced Command and Control (C2) techniques commonly used by threat actors: DNS tunneling and encrypted HTTPS C2 communication via Meterpreter. The exercise was conducted in an isolated home lab environment to develop and validate detection capabilities that are directly applicable to real-world SOC operations.

Both attack vectors were successfully simulated and detected using open-source tooling (Zeek and Splunk). Custom SPL detection queries were developed, MITRE ATT&CK techniques were mapped, and a PICERL incident response playbook was produced. This report presents findings as they would appear in a professional security consulting engagement.

OVERALL RISK RATING

HIGH — Active C2 communication enables persistent attacker access, data exfiltration, and lateral movement if undetected.

2. ISSUE NAME & DESCRIPTION

ISSUE-001 DNS Tunneling via dnscat2

DNS tunneling encodes arbitrary data inside DNS query and response packets to bypass network security controls. The attacker runs a dnscat2 server and the compromised host sends data as crafted DNS queries, effectively creating a covert C2 channel over port 53 — a protocol almost universally allowed through firewalls.

ISSUE-002 Encrypted HTTPS C2 via Meterpreter

Meterpreter reverse HTTPS payloads establish an encrypted C2 channel over TLS on port 443. Because the traffic is encrypted and uses a common port, it often blends with legitimate web traffic. Detection requires analysis of TLS metadata (JA3 fingerprints, certificate anomalies, connection patterns) rather than payload inspection.

3. TECHNICAL DETAILS

3.1 Lab Environment

Component	Details
Attacker Machine	Kali Linux (VirtualBox VM)
Victim Machine	Ubuntu Server — robertserver (VirtualBox VM)
Network	Isolated NAT Network — 192.168.56.0/24
Network Monitor	Zeek 6.x — zeek:dns, zeek:ssl, zeek:conn logs
SIEM	Splunk Enterprise (local) — Universal Forwarder on victim
C2 Framework	dnscat2 (DNS tunneling), Metasploit meterpreter/reverse_https

3.2 Attack Simulation — DNS Tunneling (dnscat2)

The dnscat2 server was started on the Kali attacker machine. The victim Ubuntu host executed the dnscat2 client, establishing a covert C2 session by encoding command traffic inside DNS query subdomains. The following behaviours were observed:

- High-frequency DNS queries to a single domain within short time windows
- Abnormally long DNS query names (subdomain length > 50 characters)
- Consistent use of TXT and NULL record types — atypical for legitimate traffic
- DNS query rate spikes inconsistent with normal user activity baselines
- Single source IP responsible for disproportionate DNS query volume

SPL Detection Query — DNS Tunneling:

```
index=zeek sourcetype="zeek:dns" | eval query_len=len(query) | where query_len > 50 OR
(record_type="TXT" OR record_type="NULL") | stats count AS dns_requests, dc(query) AS
unique_queries BY src_ip, dest_ip | where dns_requests > 100 | sort -dns_requests
```

3.3 Attack Simulation — Meterpreter HTTPS C2

A Metasploit reverse_https payload was generated and executed on the victim host, establishing an encrypted TLS session back to the Kali listener on port 443. Detection focuses on SSL metadata rather than payload content. Key indicators observed:

- Self-signed TLS certificates with anomalous or absent Subject Alternative Names (SANs)
- JA3 fingerprint matching known Meterpreter client fingerprints
- Consistent beacon interval — periodic connections at near-identical time gaps
- High bytes_out / bytes_in ratio on port 443 connections (attacker pulling data)
- TLS connections to IPs with no corresponding DNS resolution (direct IP C2)
- Long-lived SSL sessions with low data volume — indicative of keep-alive beaconing

SPL Detection Query — Meterpreter HTTPS C2:

```
index=zeek (sourcetype="zeek:ssl" OR sourcetype="zeek:conn") | eval
is_self_signed=if(validation_status="self signed certificate", 1, 0) | where dest_port=443 AND
is_self_signed=1 | stats count AS conn_count, sum(orig_bytes) AS bytes_out,
sum(resp_bytes) AS bytes_in, dc(dest_ip) AS unique_dests BY src_ip, ja3 | where conn_count > 5 |
eval ratio=round(bytes_out / (bytes_in + 1), 2) | sort -conn_count
```

3.4 Zeek Parsing — Key Configuration Fix

During ingestion, Zeek TSV log fields were misaligning in Splunk due to an inherited FIELD_HEADER_REGEX configuration from CASE-003. The fix required adding a dedicated props.conf stanza to correctly parse the #fields header line:

```
[zeek:dns] FIELD_HEADER_REGEX = ^#fields\s+(.*) HEADER_FIELD_LINE_NUMBER = 0 [zeek:ssl]
FIELD_HEADER_REGEX = ^#fields\s+(.*) HEADER_FIELD_LINE_NUMBER = 0
```

4. IMPACT ASSESSMENT

Issue	CIA Impact	Business Risk	Severity
DNS Tunneling C2 (ISSUE-001)	Confidentiality: HIGH Integrity: MEDIUM Availability: LOW	Undetected data exfiltration via DNS; bypasses most firewall rules and DLP controls. Attacker maintains persistent covert access.	HIGH
Meterpreter HTTPS C2 (ISSUE-002)	Confidentiality: HIGH Integrity: HIGH Availability: MEDIUM	Full remote shell access over encrypted channel; enables credential harvesting, lateral movement, ransomware staging, and data theft.	HIGH

5. MITRE ATT&CK MAPPING

Technique ID	Technique Name	Tactic	Observed Behaviour
T1071.004	Application Layer Protocol: DNS	Command & Control	dnscat2 encoded C2 commands inside DNS query subdomains
T1071.001	Application Layer Protocol: Web Protocols	Command & Control	Meterpreter reverse HTTPS beacon on port 443

T1573.002	Encrypted Channel: Asymmetric Cryptography	Command & Control	Meterpreter TLS encryption conceals payload contents
T1041	Exfiltration Over C2 Channel	Exfiltration	Data exfiltration possible through both DNS and HTTPS C2 channels
T1095	Non-Application Layer Protocol	Command & Control	DNS (UDP/53) used as covert transport layer for dnscat2

6. REMEDIATION RECOMMENDATIONS

DNS Tunneling Controls

- Deploy DNS security solutions (e.g., Cisco Umbrella, Infoblox) that analyse query entropy and flag anomalous subdomain lengths.
- Restrict outbound DNS to authorised resolvers only; block direct UDP/53 to external IPs.
- Implement DNS query rate-limiting per source IP at the perimeter firewall.
- Alert on DNS queries containing encoded payloads (base32/base64 patterns in subdomains).
- Baseline normal DNS behaviour per endpoint and alert on statistical deviations.

HTTPS C2 Controls

- Implement SSL/TLS inspection on the network perimeter to analyse encrypted traffic metadata.
- Deploy JA3/JA3S fingerprinting to detect known malicious TLS client fingerprints (Meterpreter, Cobalt Strike).
- Block or alert on TLS connections to IPs with self-signed certificates that lack valid SANs.
- Monitor for beaconing behaviour: connections with consistent timing intervals to the same destination.
- Enforce certificate pinning and restrict outbound HTTPS to approved proxy servers where feasible.

General Detection Engineering

- Enrich Zeek conn.log with threat intelligence feeds to flag known-bad IPs in real time.
- Develop Splunk correlation searches combining DNS and SSL anomalies (a single host exhibiting both warrants immediate investigation).
- Implement UEBA baselines for network behaviour to reduce false positive rates on volume-based detections.
- Review and test Splunk field extraction configurations when onboarding new log sources to prevent parsing issues.

7. PICERL INCIDENT RESPONSE PLAYBOOK (SUMMARY)

P	Preparation	Ensure Zeek is deployed on network taps with dns, ssl, and conn logging enabled. Splunk Universal Forwarder configured with correct FIELD_HEADER_REGEX for Zeek TSV logs. SOC runbooks documented for DNS and HTTPS C2 alert triage.
I	Identification	SPL alert fires on: (a) DNS query volume >100/src_ip with query_len >50, or TXT/NULL records; (b) HTTPS connections with self-signed certs, JA3 anomalies, or beaconing patterns. Analyst validates alert, correlates with asset inventory.
C	Containment	Isolate affected endpoint from network. Block identified C2 IPs/domains at perimeter firewall. Null-route DNS responses for tunneling domains. Disable compromised user accounts if credential exposure suspected.
E	Eradication	Remove malicious payload from victim host (dnscat2 client binary, Meterpreter stager). Kill persistence mechanisms (cron jobs, systemd units, registry run keys). Reset credentials for all accounts accessible from compromised host.
R	Recovery	Restore host from known-good backup or reimage. Re-enroll in asset management and EDR. Verify network logging resumes cleanly. Monitor host intensively for 72 hours post-recovery.
L	Lessons Learned	Document detection gap that allowed C2 to establish before alerting. Review DNS resolver policies and SSL inspection coverage. Update detection rules with IOCs from this incident. Share threat intel with peer teams.

8. REFERENCES

- [1] MITRE ATT&CK — T1071.004 (DNS): <https://attack.mitre.org/techniques/T1071/004/>
- [2] MITRE ATT&CK — T1071.001 (Web Protocols): <https://attack.mitre.org/techniques/T1071/001/>
- [3] MITRE ATT&CK — T1573.002 (Encrypted Channel): <https://attack.mitre.org/techniques/T1573/002/>
- [4] dnscat2 GitHub Repository: <https://github.com/iagox86/dnscat2>
- [5] Zeek Network Security Monitor: <https://zeek.org/>
- [6] Splunk SPL Documentation: <https://docs.splunk.com/Documentation/Splunk/latest/SearchReference/>
- [7] JA3 TLS Fingerprinting: <https://github.com/salesforce/ja3>
- [8] SANS Internet Storm Center — DNS Tunneling Detection Techniques
- [9] Metasploit Framework Documentation: <https://docs.metasploit.com/>
- [10] NIST SP 800-61 Rev 2 — Computer Security Incident Handling Guide

This report was produced as part of a home lab detection engineering portfolio. All simulations were conducted in an isolated environment. Full lab files, SPL queries, Zeek configs, and playbooks available at: github.com/Robertnile